POUR ALLER PLUS LOIN

- **Privilégier l'authentification multifacteur** lorsque cela est possible, en particulier lorsque la connexion est accessible depuis l'extérieur du réseau de l'organisme.
- **Limiter le nombre de tentatives d'accès** aux comptes utilisateurs sur les postes de travail et bloquer l'accès au compte temporairement ou non, lorsque sa limite est atteinte.
- **Imposer, pour les administrateurs, une entropie des mots de passe plus élevée et un renouvellement** selon une périodicité pertinente et raisonnable.
- Mettre en œuvre des moyens techniques pour **faire respecter les règles relatives à l'authentification** (ex. : blocage du compte en cas de non-renouvellement du mot de passe d'un administrateur).
- La CNIL met à disposition sur son site web un outil[18] pour calculer la complexité des mots de passe demandés aux utilisateurs, selon chaque cas d'usage (mot de passe seul, avec restriction d'accès ou avec un matériel détenu par la personne).
- Éviter, si possible, que les identifiants (ou « *logins* ») des utilisateurs et ceux des administrateurs soient ceux des comptes définis par défaut par les éditeurs de logiciels et désactiver les comptes par défaut.
- **Stocker les mots de passe de façon sécurisée** transformés (« *hash* ») avec une fonction spécifiquement conçue à cette fin et utilisant toujours un sel ou une clé[19] (voir la fiche n°21 - Chiffrement, hachage, signature). Une clé ne doit pas être stockée dans la même base de données que les empreintes générées.
- L'ANSSI a publié avec la collaboration de la CNIL[20] des recommandations relatives à l'authentification multifacteur et aux mots de passe. Se référer également aux guides[21] publiés par l'ANSSI pour aider les développeurs et administrateurs dans leurs choix d'algorithmes cryptographiques, de dimensionnement et d'implémentation.
- Pour les autorités administratives, les annexes du référentiel général de sécurité (RGS)[22] s'appliquent, notamment les annexes B1 et B2 concernant respectivement les mécanismes cryptographiques et la gestion des clés utilisées.

18 « Vérifier sa politique de mots de passe », cnil.fr

19 On appelle « sel » l'aléa utilisé lorsqu'il est différent pour chaque mot de passe stocké et « clé » lorsque l'aléa utilisé est commun à la transformation d'un ensemble de mots de passe (ex. : pour toute une base de données).

20 « Recommandations relatives à l'authentification multifacteur et aux mots de passe », cyber.gouv.fr

21 « Mécanismes cryptographiques », cyber.gouv.fr

22 « Le référentiel général de sécurité version 2.0 : les documents », cyber.gouv.fr